



February 19, 2025

California Privacy Protection Agency
Attn: Legal Division – Regulations Public Comment
2101 Arena Boulevard
Sacramento, CA 95834

RE: Public Comment on CCPA Updates, Cyber, Risk, ADMT, and Insurance Regulations

Dear California Privacy Protection Agency:

On behalf of the advertising industry, we provide these comments in response to the California Privacy Protection Agency’s (“CPPA” or “Agency”) notice of proposed rulemaking to update the state’s regulations implementing the California Consumer Privacy Act (“CCPA”) and to issue new regulations governing risk assessments, automated decisionmaking technology (“ADMT”), cybersecurity audits, and insurance companies.¹ Below we provide comments on the Agency’s proposed ADMT rules, cybersecurity audit regulations, and the proposed updates to the existing CCPA regulations.

The CPPA’s regulatory package would make significant changes to existing privacy mandates and broach entirely novel areas in ways that likely overstep the CPPA’s authority to regulate. The proposed ADMT rules, for example, would create costly new risk assessment and opt-out requirements for an extraordinarily broad swath of activity in ways that would impede routine computing functions that benefit consumers, hamper the economy, hinder innovation, and impose remarkable costs on consumers and businesses alike. In addition, certain proposed regulations would impose unnecessary and aggressive compliance timelines on businesses and would substitute prescriptive requirements in place of text that presently provides workable flexibility. By the Agency’s own estimate, the proposed regulations will cost \$3.5 billion for California companies alone to implement in the first year, with annual costs to average \$1 billion across the first ten years following implementation.² These estimates likely severely underestimate the impact the proposed rules will have across the U.S. economy at-large. The proposed rules will impact consumers the most through lost access to computing functions that enable efficiencies and modern conveniences, significant reduction in innovative new offerings, and other impacts that consumers likely do not desire or expect.

We ask the Agency to make necessary revisions to the proposed regulations in line with the suggestions in this submission. If finalized in their present form, the proposed rules are likely to significantly impact consumers and businesses of all sizes that make up the economy. Given the scope and breadth of the regulatory package, the Agency should afford businesses at least a year to

¹ See *Notice of Proposed Rulemaking*, CALIFORNIA PRIVACY PROTECTION AGENCY (Nov. 22, 2024), available [here](#).

² *Standard Regulatory Impact Assessment: California Privacy Protection Agency* (Oct. 2024) at 63, available [here](#) (hereinafter, “SRIA”).

comply with new mandates before they become enforceable. We submit comments on the following specific areas with the goal of improving the proposed regulations to benefit consumers and businesses, ensure new regulations respect the bounds of the regulatory authority conferred on the Agency by the CCPA, enhance clarity in the regulatory text, and further the operational feasibility of new mandates set forth in the proposed rules:

- I. Comments on Proposed Regulations on ADMT and Cybersecurity Audits**
 - a. The Proposed Definition of ADMT Is Overly Broad and Confusing
 - b. The Proposed Opt-Out and Risk Assessment Requirements for “Behavioral Advertising” Would Violate the First Amendment and Extend Beyond the CPPA’s Authority to Regulate
 - c. The CPPA Should Remove the Proposed Opt-Out for Uses of Personal Information to Train ADMT or AI
 - d. The CPPA Should Clarify That Critical CCPA Exemptions Apply to the ADMT Regulations
 - e. The ADMT Pre-Use Notice Requirements Should Be Removed or Should Clarify Ways Third Parties Can Comply
 - f. The CPPA Should Not Require Preemptive Submission of ADMT and AI Risk Assessments
 - g. Cybersecurity Audit Regulations Should Be Updated to Prioritize Outcomes Rather Than Specific Controls, Acknowledge Existing Audit Frameworks, and Preserve Confidential Information
- II. Comments on Proposed Updates to CCPA Regulations**
 - a. “Immediate” Opt-Out Requirements Are Overly Rigid and Unnecessary
 - b. Opt-Out Signal Status Display Requirements Should Be Appropriately Scoped
 - c. Requirements to Ensure Personal Information Remains Deleted or Corrected Should Apply Only to Previously Collected Data
 - d. Proposed New Requirements Related to Data Sources Should Remain Optional
 - e. The Regulations Should Clarify How Businesses Can Confirm Certain Sensitive Personal Information
 - f. The Scope of CCPA Applicability for Nonprofits Should Be Clarified and Aligned With the Statute
 - g. Notice Requirements Should Be Channel Agnostic and Should Allow for Flexibility in Connected Device Settings
- III. The CPPA Should Permit Businesses at Least a Year to Comply with New Mandates Before They Become Enforceable**

As the nation’s leading advertising and marketing trade associations, we collectively represent thousands of companies across the country, including California. These companies range from small businesses to household brands, publishers, nonprofits, advertising agencies, and technology providers. Our combined membership includes more than 2,500 companies that power the commercial Internet, which accounted for 12 percent of total U.S. gross domestic product

(“GDP”) in 2020.³ Our group has more than a decade’s worth of hands-on experience it can bring to bear on matters related to consumer privacy and controls. We would welcome the opportunity to engage with the CPPA further on the points we discuss in these comments.

I. Comments on Proposed Regulations on ADMT and Cybersecurity Audits

The proposed regulations regarding ADMT would create extraordinarily broad, foundational definitions for basic technologies in ways that would severely impede the computing that powers the modern economy and bestows significant benefits on consumers. The rules would also construct an entirely new opt-out regime for “behavioral advertising” and uses of personal information to train ADMT, in contravention of the CCPA statute itself and the authority conferred on the CPPA to issue regulations. Finally, the proposed rules would stand up novel cybersecurity audit requirements, require regular submission of risk assessments and cybersecurity audits to the Agency, create onerous new Pre-Use Notice requirements for ADMT, and fail to extend critical CCPA exemptions to new ADMT mandates. We address these issues below.

a. The Proposed Definition of ADMT Is Overly Broad and Confusing

The Agency’s proposed definition of ADMT includes “any technology that processes personal information and uses computation to execute a decision, replace human decisionmaking, or substantially facilitate human decisionmaking...,” including “software or programs... derived from machine learning, statistics, other data-processing techniques, or artificial intelligence.”⁴ The breadth of this definition encompasses virtually any kind of modern computing process, including basic and routine processing activities. In testimony before the Agency, concerns have already been raised about the broad scope of the proposed ADMT regulations and the lack of nuance in requirements for processing activities that may pose no quantifiable risk of harm to consumers. The CPPA should look to risk-based frameworks for ADMT rather than creating rigid mandates without appropriately assessing actual risks to consumers. Without critical amendments to cabin and clarify the ADMT definition’s scope, the rules will likely have extraordinarily broad and unintended impacts. The proposed scope of ADMT, and the lack of clarity surrounding its bounds, draws into question what kinds of data processing practices require a risk assessment and are subject to opt-out and access requests under the proposed rules.

In addition, requirements and provisions related to artificial intelligence (“AI”) should be removed from the proposed regulations entirely because they extend beyond the scope of the Agency’s authority to regulate. The CCPA itself does not mention AI, nor does it give the Agency authority to set foundational regulations for AI that will impact the entirety of the economy. As a result, attempting to regulate AI exposes the Agency to criticism of scope creep. Moreover, the Agency’s rules propose to regulate AI in a blunt fashion rather than setting forth a nuanced framework that appropriately allocates compliance responsibilities amongst entities that develop and deploy AI applications. For example, the proposed rules do not appropriately address different

³ John Deighton and Leora Kornfeld, *The Economic Impact of the Market-Making Internet*, INTERACTIVE ADVERTISING BUREAU, 15 (Oct. 18, 2021), available [here](#).

⁴ Cal. Code Regs., tit. 11, § 7001(f) (proposed), available [here](#).

ways in which developers and deployers of AI applications may control inputs in the underlying AI. Moreover, the proposed ADMT rules encroach on areas of AI that the California legislature has sought to regulate through recently-enacted legislation, such as the California AI Transparency Act.⁵ The CCPA—a consumer privacy statute—does not give the Agency authority to issue economy-wide AI regulations. The proposed ADMT rules set forth an impractical and unworkable approach that will hinder AI development and deployment in California, thereby damaging the broader AI innovation ecosystem.

In addition, the proposed ADMT rules are also confusing and unclear. The proposed ADMT definition is so broad that the Agency had to clarify that rudimentary data processing functions like spellcheck, calculators, and spreadsheets do not constitute ADMT “provided that the technologies do not execute a decision, replace human decisionmaking, or substantially facilitate human decisionmaking.” This exemption creates more confusion rather than offering much needed clarity on the scope of covered activity. It is not clear, for example, whether a business’s internal spreadsheet of its own customers’ addresses, past purchases from the business, and dates of purchases used to advertise a good that the business sells would constitute a technology that “executes a decision,” “replaces human decisionmaking,” or “substantially facilitates human decisionmaking” subject to the regulations. The definition also draws into question whether software or functionality that is not specifically exempted from the ADMT definition by name must be compliant with the rules. The lack of clarity in the ADMT definition’s scope and its exemptions could lead to consumers opting out of data processing functions they rely on and expect.

For example, a local grocery store owner who alerts his/her customer to available maple syrup discounts when the customer purchases pancake mix may be covered by these proposed ADMT regulations. The customer and grocer may reasonably understand this recommendation as a matter of helpful customer service. However, the broad ADMT definition could render this form of customer outreach to be subject to the proposed ADMT rules. By veering from the legally prescribed mandate and regulatory authority set forth in the CCPA, the Agency proposes to regulate all consumer-business interactions, be they customer service interactions, welcome product or service recommendations, or other day-to-day business-consumer exchanges.

Regulatory incursions into areas of the economy the CPPA is not specifically authorized to regulate come at a cost. Even by the Agency’s own, likely under-representative accounting, nearly 100,000 California jobs would be lost in the first year after the proposed ADMT rules take effect.⁶ Small businesses would additionally be burdened with up to \$98,896 in initial costs to comply, with estimated total ongoing costs of \$19,317.⁷ Small businesses in California number in the tens of thousands, and the estimated costs of the proposed ADMT rules would likely deeply cut into those small businesses’ bottom line. Small businesses stand to lose the most from the Agency’s proposed regulatory overreach. Even if not directly subject to ADMT mandates, smaller firms oftentimes partner with and rely on the efficiency and scale of larger partners to find interested audiences for their products and services and would thus suffer detrimental and potentially enterprise-threatening

⁵ California SB 942, the California AI Transparency Act (2024 Gen. Assemb.), located [here](#).

⁶ SRIA at 94.

⁷ *Id.* at 100.

impacts from the proposed ADMT rules. The breadth of the proposed ADMT rules would stifle innovation and jeopardize the entrepreneurial culture which has defined California and the United States by limiting competition, constraining growth, diminishing jobs (as noted in the Agency’s own findings), and limiting consumer choices.

Finally, the CPPA’s proposed definition of ADMT and its approach to the technology stands in stark contrast to most other states that have passed data privacy laws. Most states regulate “solely” automated processing, and permit consumers to opt out of that processing only when it results in decisions that produce *legal or similarly significant effects concerning a consumer*.⁸ The CPPA’s proposed ADMT rules, by contrast, apply to virtually *all automated processing* for “significant decisions,” “extensive profiling,” and “training uses of ADMT,” broadly construed, and would create requirements for ADMT even if such automated processing is not used to make a decision about a consumer.⁹ The breadth of the ADMT definition, coupled with its extension to more than solely automated decisions that produce legal or similarly significant effects concerning consumers themselves, would have a widespread and detrimental impact on various data processing functions that provide efficiencies and benefits across the economy. In addition, the related risk assessment requirements for covered uses of ADMT would extend beyond what is required by other state laws, such as laws and regulations that already provide detailed requirements for risk assessments in Colorado.¹⁰ The CPPA should narrow the broad scope of the ADMT definition and harmonize risk assessment requirements with other states to minimize unintended results for Californians, provide much needed consistency, and offer more clarity for businesses.

b. The Proposed Opt-Out and Risk Assessment Requirements for “Behavioral Advertising” Would Violate the First Amendment and Extend Beyond the CPPA’s Authority to Regulate

The proposed ADMT rules would make “behavioral advertising,” as defined, a form of “extensive profiling” subject to consumer opt-out requests and risk assessment requirements.¹¹ Under the CPPA’s proposed definition of “behavioral advertising,” the targeting of advertising to a consumer “based on the consumer’s personal information obtained from *within the business’s own distinctly-branded websites, applications, or services*” would be subject to opt-out and risk assessment mandates.¹² The proposed definition of ADMT would apply to a business’s use of data to engage in first-party advertising by marketing its own products or services to its existing customers. The proposal would raise substantial First Amendment concerns as well as exceed the CPPA’s regulatory authority under to the CCPA.

The proposed opt-out for “behavioral advertising” would create First Amendment concerns by unreasonably hindering lawful commercial speech. The Supreme Court has long held that advertising is a form of commercial speech that protects businesses in their right to free expression

⁸ See, e.g., Colo. Rev. Stat. § 6-1-1306(a)(I)(C); Conn. Gen. Stat. § 42-518(a)(5); Va. Code Ann. § 59.1-577(A)(5).

⁹ Cal. Code Regs., tit. 11, § 7200 (proposed).

¹⁰ See, e.g., 4 Colo. Code Regs. § 904-3, Rule 8.01 – 8.06.

¹¹ Cal. Code Regs., tit. 11, § 7200(a)(2) (proposed).

¹² *Id.* at § 7001(g) (emphasis added) (proposed).

and consumers in their right to receive accurate information through advertising.¹³ A consumer right to opt out of all first-party advertising would unreasonably hinder businesses' lawful and constitutionally protected commercial speech. In addition, the proposed risk assessment requirements for "behavioral advertising" would abridge the First Amendment by requiring businesses to make subjective determinations. Requiring businesses to complete risk assessments for the advertising they deliver to their existing customer base compels them to speak and requires them to opine on potential negative impacts and "harms" of data processing for advertising.¹⁴ The First Amendment protects the right to speak in addition to the right to refrain from speaking.¹⁵ Compelled disclosure—of even entirely commercial information—requires First Amendment scrutiny.¹⁶ In addition, the 9th Circuit has recently held similar risk assessment requirements to be unconstitutional.¹⁷ As a result, the proposed opt-out and risk assessment requirements for "behavioral advertising" likely run afoul of the First Amendment.

In addition, regulating "behavioral advertising," and creating a brand new mandated limit for the activity, extends beyond the scope of the CCPA and the CPPA's regulatory authority set forth in law. The CCPA, as passed by the legislature and then amended via ballot initiative by California voters, includes no right to limit a business's use of data collected from its *own distinctly-branded websites, applications, or services* to market its own products and services to an existing customer. In fact, the law itself expressly exempts from the scope of available opt outs personal information that is processed through "services with which the consumer intentionally interacts."¹⁸ An advertisement served by a business the consumer already patronizes clearly falls within the scope of this CCPA exemption. Creating such an entirely new opt-out right for first-party advertising practices through these regulations would contradict the law, as approved by Californians through the ballot process, and further expand the scope of the Agency.

The text of the CCPA itself demonstrates that the law addresses the full scope of advertising-related opt-outs contemplated under law and does not confer upon the Agency any authority to augment or create new advertising mandates. For example, the CCPA's opt-out rights for "sales" and "sharing" for "cross-context behavioral advertising" both involve a transfer of data *to a separate entity or unrelated party*—not an intra-business use of personal information it collected to advertise to its existing customer base.¹⁹ In addition, the CCPA provides only one opt-out right related to internal data processing, and that right is narrowly scoped to "sensitive personal

¹³ See, e.g. *Central Hudson Gas & Electric v. Public Service Commission*, 447 U.S. 557, 564-66 (1980).

¹⁴ Cal. Code Regs., tit. 11, § 7152(a)(5) (proposed).

¹⁵ See, e.g., *Wooley v. Maynard*, 430 U.S. 705, 714 (1977).

¹⁶ See, e.g., *Zauderer v. Off. Of Disciplinary Counsel of Sup. Ct. of Ohio*, 471 U.S. 626, 629, 650-53 (1985).

¹⁷ *NetChoice, LLC v. Bonta*, No. 23-2369, slip op. at 25, 34-37 (9th Cir. Aug. 16, 2024).

¹⁸ See Cal. Civ. Code § 1798.140(k) (defining "cross-context behavioral advertising" and specifically exempting first-party advertising activities from its scope).

¹⁹ See *id.* at § 1798.140(ad) (defining "sale" as making personal information available "to a third party" for monetary or other valuable consideration); Cal. Civ. Code §. at § 1798.140(ah) (defining "share" as making available personal information "to a third party" for cross-context behavioral advertising).

information” that is used for particular, specifically enumerated purposes.²⁰ Moreover, the law explicitly permits other forms of defined advertising practices, such as “advertising and marketing” and “nonpersonalized advertising,” without opt out rights for those activities or any suggestion that the Agency has authority to create them. The CCPA does not contemplate the activity the CPPA proposes to define as “behavioral advertising” or a limit for commonplace business activities such as product recommendations, for example.

The opt-out and risk assessment requirements for “behavioral advertising” are therefore beyond the CPPA’s authority to regulate, as the CCPA itself does not contemplate or direct the Agency to create a new limit on a business’s ability to use data it collects from its *own distinctly-branded websites, applications, or services* to market its own products and services. In addition, the requirements abridge the First Amendment by unreasonably burdening protected speech—first-party advertising—and by compelling speech through risk assessments. The proposed opt-out right and risk assessment requirements for “behavioral advertising” extend beyond the CPPA’s authority to regulate, violate the First Amendment, and should be struck from the proposed regulations.

c. The CPPA Should Remove the Proposed Opt-Out for Uses of Personal Information to Train ADMT or AI

The proposed regulations would create a consumer opt-out right for uses of personal information to train ADMT or AI, *i.e.*, “the process through which [ADMT or AI] discovers underlying patterns, learns a series of actions, or is taught to generate a desired output.”²¹ Businesses’ use of personal information to train ADMT or AI does not always impact consumers individually. Applying an opt-out to ADMT or AI training could extend to even low-risk processing applications that have no impact on consumers themselves. Moreover, removing data from automated processing functions via application of an opt-out right could have the unintended effect of impairing the functioning of the ADMT or AI itself. ADMT and AI systems should be trained on a broad set of personal information to help further equitable and unbiased outcomes. Consumer opt-out rights should apply only in instances when ADMT or AI applications may result in a decision that is of legal or similar significance to consumers’ own lives. Applying opt-out rights to *every use of personal information to train an automated system*, as proposed by the CPPA’s regulations, would severely threaten product development, innovation, and basic and rudimentary data processing activities that benefit consumers and the economy. The proposed extension of the ADMT opt-out right to uses of personal information to train ADMT or AI should consequently be outside of the scope of the proposed rules.

²⁰ See *id.* at § 1798.121 (creating an opt-out right for the use and disclosure of sensitive personal information for a specific list of defined uses); *id.* at § 1798.140(ae) (defining “sensitive personal information” to include a finite list of data elements).

²¹ Cal. Code Regs. tit. 11, §§ 7001(ff), 7150(b)(4) (proposed).

d. The CCPA Should Clarify That Critical CCPA Exemptions Apply to the ADMT Regulations

The proposed rules would incorporate CCPA exemptions in a piecemeal fashion rather than extending them to the ADMT rules in a clear and complete way. This proposed incomplete extension of statutory exemptions to the proposed ADMT rules would create the possibility that key exemptions deliberated during the CCPA's passage, such as those related to trade secrets and commercial credit reporting, and directly approved by the people of California by ballot measure, would not apply to the ADMT rules.

The draft ADMT rules, for example, do not extend CCPA exemptions related to commercial credit reporting to the ADMT regulations. The CCPA itself makes clear that the law's opt-out rights do not apply to a commercial credit reporting agency's collection, processing, sale, or disclosure of "business controller information," as defined, to the extent the commercial credit reporting agency uses the business controller information solely to identify the relationship of a consumer to a business that the consumer owns or contact the consumer only in the consumer's role as the owner, director, officer, or management employee of the business.²² If this key exemption is not carried over to the ADMT opt-out right, it is possible that critical data and automated processing needed to efficiently and effectively extend business credit could be severely impeded through execution of a consumer's opt-out request. Such a result would be detrimental to the economy as well as Californians who need to obtain lines of credit for businesses they own and operate.

The draft ADMT rules similarly make no mention of extending exemptions for trade secret protections to the ADMT rules. The CCPA itself states that the Agency must establish exemptions relating to trade secrets and intellectual property rights "with the intention that trade secrets should not be disclosed in response to a verifiable consumer request."²³ However, the draft ADMT regulations would require businesses to disclose the "logic" used in ADMT and the "output" of the ADMT in response to consumer access requests, as well disclose such information in a Pre-Use Notice, without any limitations relating to a business's trade secrets or intellectual property.²⁴ According to the proposed rules, businesses would be required to disclose "assumptions of the [ADMT] logic," "how the business will use the output," the "intended output," and "key parameters that affect the output."²⁵ Such information may include disclosures surrounding business's proprietary technology and trade secrets, and requiring disclosures without appropriate protections could result in anti-competitive impacts. The CCPA itself prohibits the ADMT regulations from requiring a business to divulge trade secrets. The CCPA should take steps to clarify that exemptions in the statutory text extend to the ADMT regulations.

²² Cal. Civ. Code § 1798.145(o)(1).

²³ *Id.* at § 1798.185(a)(3).

²⁴ Cal. Code Regs. tit. 11, §§ 7152(a)(3)(g); 7220(c)(5); 7224(b) (proposed).

²⁵ *Id.* at § 7224(b) (proposed).

e. The ADMT Pre-Use Notice Requirements Should Be Removed or Should Clarify Ways Third Parties Can Comply

The proposed rules would require businesses that use ADMT to provide consumers with a “Pre-Use Notice” that must be presented “in the manner in which the business primarily interacts with the consumer” before the business processes personal information using ADMT.²⁶ The CCPA does not give the Agency authority to issue a regulation to this effect, and the Pre-Use Notice requirements create First Amendment concerns. As a result, these requirements should be removed from the proposed regulations, or at the very least should clarify ways third parties can comply with new Pre-Use Notice mandates.

First, the CCPA itself does not permit regulations on Pre-Use Notice of ADMT.²⁷ In addition, the Pre-Use Notice requirements compel businesses to speak in contravention of the First Amendment. The requirements mandate that businesses disclose information such as “the intended output of the [ADMT] and how the business plans to use the output[.]”²⁸ This requirement regulates speech that is protected by the First Amendment and forces businesses to speak in specific ways. Because the Pre-Use Notice requirements extend beyond the scope of the Agency’s authority to regulate and abridge the First Amendment, they should be removed from the CPPA’s regulatory proposal.

If the Agency does not remove the Pre-Use Notice requirements in their entirety, it should at least clarify how a third-party entity that collects personal information from a source other than directly from the consumer can comply with these notice requirements. In the CCPA itself and the CCPA regulations addressing notice obligations, third parties that do not have direct relationships with consumers have been given the option of satisfying requisite requirements by providing required information prominently and conspicuously on their Internet websites or by providing applicable notices through the California Data Broker Registry.²⁹ The CPPA should similarly provide those options to third parties in the context of required ADMT Pre-Use Notice disclosures. In addition, the underlying CCPA regulations should be updated in Section 7012(i) to reference the CPPA rather than the California Attorney General (“CA AG”), as the entity in charge of managing registration has been changed from the CA AG to the CPPA.³⁰

f. The CPPA Should Not Require Preemptive Submission of ADMT and AI Risk Assessments

The proposed regulations would require businesses to submit required ADMT and AI risk assessments within 24 months of the effective date of the rules, and abridged forms of risk

²⁶ *Id.* at §§ 7220(a), (b) (proposed).

²⁷ Cal. Civ. Code § 1798.185(a)(16) (giving the CPPA authority to issue regulations “governing access and opt-out rights with respect to businesses’ use of automated decisionmaking technology[.]”).

²⁸ Cal. Code Regs. tit. 11, § 7220(c)(5)(B) (proposed).

²⁹ Cal. Civ. Code § 1798.100(b); Cal. Code Regs. tit. 11, § 7012(i).

³⁰ Cal. Code Regs. tit. 11, § 7012(i); *see also* Cal. Civ. Code 1798.99.80 et seq.

assessments to the Agency annually thereafter.³¹ Regular submission of such assessments would be extremely burdensome for businesses as well as out-of-step with other state privacy laws. No other law mandating risk assessments requires proactive submission of an assessment to an agency absent a previous allegation of wrongdoing. The proposed requirement to affirmatively submit risk assessments to the Agency would create unnecessary risks for businesses without any measurable countervailing benefits to consumers or privacy. The CPPA should remove this requirement from the proposed regulations.

g. Cybersecurity Audit Regulations Should Be Updated to Prioritize Outcomes Rather Than Specific Controls, Acknowledge Existing Audit Frameworks, and Preserve Confidential Information

The CPPA’s proposed cybersecurity audit regulations would create an entirely new framework for assessing cybersecurity governance. The global marketplace has already coalesced around well-known standards for information security management systems, such as the International Organization for Standardization (“ISO”) certification programs and the National Institute for Standards and Technology (“NIST”) Cybersecurity Framework.³² These commonly used, existing audit frameworks are outcomes-driven; instead of requiring businesses to use specific security controls, existing audit frameworks provide flexibility for businesses to achieve preferable security outcomes. By contrast, the CPPA’s proposed audit requirements would require businesses to focus on implementing specific controls.³³ This approach threatens to render those controls obsolete as technology progresses and new, more effective ways to protect information are developed. For example, the proposed rules focus on multi-factor authentication and password requirements when most companies are increasingly moving towards passkeys as a method for authenticating users. To avoid overly prescriptive and inflexible audit requirements that cannot adjust to advancements in technology, the CPPA should redraft the proposed cybersecurity audit regulations so they are outcomes-driven rather than dependent on specific security controls.

In addition, the proposed regulations make no mention of leading cybersecurity audit standards that are widely used today. The proposed regulations would allow a business to rely on another cybersecurity audit or evaluation only if it “meets all of the requirements of” the CPPA’s proposed regulations.³⁴ Functionally, this provision would be meaningless, because the CPPA’s proposed audit requirements differ significantly from existing, prevalent audit frameworks from ISO and NIST. The CPPA should revise the language of Section 7123(f) in the proposed rules to state that commonly used ISO and NIST evaluations satisfy the regulations’ requirements to complete a cybersecurity audit. The CPPA should also ensure that there are reasonable limits on any requirements for businesses to submit full cybersecurity audits to the Agency. For example, the CPPA should ensure that the regulations state that the Agency will keep audits secure and

³¹ Cal. Code Regs. tit. 11, § 7157(a) (proposed).

³² See, e.g. ISO/IEC 27001, located [here](#); see also National Institute of Standards and Technology, NIST Cybersecurity Framework, located [here](#).

³³ See, e.g. Cal. Code Regs. tit. 11, § 7123(f).

³⁴ Cal. Code Regs. tit. 11, § 7123(f) (proposed).

confidential. In addition, the CPPA should allow for redaction of sensitive security information and other information that may be confidential to the business or divulge trade secrets.

II. Comments on Proposed Updates to CCPA Regulations

The proposed regulations would create new requirements for the timing of honoring opt-out requests and displaying the status of an opt-out preference signal; novel obligations for deletion and correction requests and confirming the data types held by a business; new applicability considerations for nonprofits; and new mandates for surfacing required notices and rights. Below we provide suggestions for the CPPA’s consideration in each of these areas.

a. “Immediate” Opt-Out Requirements Are Overly Rigid and Unnecessary

The Agency’s proposed regulations would require entities that use programmatic advertising and real-time bidding technologies to comply with consumer requests to opt out of sale and sharing “immediately.”³⁵ The proposed regulation would not give companies employing programmatic advertising and real-time bidding technologies the flexibility of 15 business days to comply with such a request.³⁶ The proposed new “immediate” compliance timeline for honoring opt-out requests is too rigid to account for internal operations and common realities associated with coordinating opt outs with other businesses. While businesses may not need 15 business days to process an opt-out request, allowing flexibility in the time needed to process a request rather than imposing an “immediate” opt-out compliance requirement would provide a reasonable buffer to account for the sometimes manual process of coordinating opt outs with other businesses. To provide helpful flexibility, the Agency should consider a rule requiring opt outs to be effectuated as soon as technically feasible but no longer than 15 business days from the date of receipt.

The proposed “immediate” timeline for programmatic advertising technologies to process opt-out requests ignores batched suppression list update processes that many programmatic advertising vendors regularly employ. Processes for data flows between providers, such as how often businesses send data to other entities or to end platforms for sales or sharing, vary significantly. Many vendors in the real-time-bidding space may update their suppression lists to account for opted-out users on a weekly basis. The current regulatory scheme also already requires businesses to “notify” all third parties who may have received personal information after the business received an opt-out request that a consumer had made an opt-out request.³⁷ This requirement to notify any third parties who received personal information after a consumer’s opt-out request effectively ensures no personal information will be subject to further sales and sharing after a business receives a consumer’s opt-out selection. As a result, the “immediate” timing requirement for programmatic advertising technologies is unnecessary, and it unreasonably singles out one type of entity in the marketplace to be subject to more aggressive compliance requirements. An “immediate” opt-out compliance requirement for programmatic technologies without reasonable exemptions would create unnecessary compliance burdens for businesses and could result in

³⁵ *Id.* at § 7026(f)(3)(A).

³⁶ *Id.*

³⁷ *Id.* at § 7026(f)(2).

unreasonably punitive enforcement. The CCPA should update the proposed regulations to require businesses to comply with opt-out requests as soon as feasibly possible but no longer than 15 business days from the date they receive a request.

b. Opt-Out Signal Status Display Requirements Should Be Appropriately Scoped

The proposed regulations would convert businesses' present option to display the status of an opt-out preference signal through an "Opt-Out Request Honored" disclosure into a mandatory requirement.³⁸ The Agency should maintain the current approach of making this mandate optional, or at the very least should ensure the new requirement is appropriately scoped through exemptions for application and enforcement as well as through clarifications regarding what constitutes a valid opt-out preference signal.

First and foremost, the requirement to honor opt-out preference signals in the existing CCPA regulations contravenes clear legislative text that makes honoring such signals optional. According to the text of the CCPA, businesses "may elect" to either (a) "[p]rovide a clear and conspicuous link on the business's internet homepage(s) titled 'Do Not Sell or Share My Personal Information'" or (b) allow consumers to "opt-out of the sale or sharing of their personal information... through an opt-out preference signal sent with the consumer's consent by a platform, technology, or mechanism, based on technical specifications to be set forth in regulations[.]"³⁹ The CCPA itself therefore gives businesses the choice to either allow consumers to opt out through a do-not-sell link on their homepage(s) or through user-enabled global privacy controls. In past regulations, the Agency has unilaterally read this option out of the law by requiring all businesses to adhere to opt-out preference signals. Through this current regulatory proposal, the Agency seeks to further entrench this interpretation by mandating that businesses affirmatively state the "status" of such signals to indicate whether or not they have been honored.

The proposed requirement to display the status of an opt-out preference signal is therefore contrary to the text of California law. It would also create significant compliance challenges. The law tasks the CCPA to issue particularized regulations governing opt-out preference signals. For example, the CCPA instructs the Agency to issue regulations to "ensure that the manufacturer of a platform or browser or device that sends the opt-out preference signal cannot unfairly disadvantage another business."⁴⁰ According to the CCPA, the Agency also must issue regulations ensure user-enabled global privacy controls "clearly represent a consumer's intent and [are] free of defaults constraining or presupposing such intent."⁴¹ The Agency has issued no regulations to this effect, which has resulted in no standardization in the marketplace regarding what constitutes a valid opt-out preference signal. As a result, the proposed requirement to indicate the "status" of a signal requires businesses to guess which signals are valid. The Agency has provided no guidance regarding which signals that are available in the marketplace meet legally prescribed requirements. Imposing a requirement to note whether signals have been "honored," without providing

³⁸ *Id.* at §§ 7025(c)(6); 7026(g); 7027(h).

³⁹ Cal. Civ. Code § 1798.135(b)(3).

⁴⁰ *Id.* at §§ 1798.135(b)(1), 185(a)(19)(A).

⁴¹ *Id.*

corresponding clarity regarding which mechanisms constitute valid signals, would create significant confusion and frustration for consumers and businesses.

The CPPA should ensure that any requirement to display the status of an opt-out preference signal is appropriately scoped through exceptions or limitations on enforcement to account for a lack of clarity regarding what constitutes a valid signal. For example, the CPPA should ensure exemptions exist for honoring signals that are set by default or are devoid of consumer choice points to initiate the signal. The CPPA should also make clear that entities that offer opt-out preference signals, such as platforms, plug-ins, and browsers, must comply with the signals in the same way as other businesses. Implementing reasonable exceptions and clarifications to the requirement to display the status of an opt-out preference signal would help prevent unfair penalties. It would also help ensure businesses are not held accountable for signals that do not comply with law or circumstances that are beyond their control, thus balancing regulatory compliance with operational feasibility.

c. Requirements to Ensure Personal Information Remains Deleted or Corrected Should Apply Only to Previously Collected Data

The proposed regulations would require businesses to ensure personal information “remains” deleted or corrected after receipt of a consumer request.⁴² This mandate should be clarified to apply to “previously collected personal information” rather than all personal information collected about a consumer on a going-forward basis to prevent the introduction of a new “do not collect” requirement and to ensure outdated information can be appropriately removed or filtered out of businesses’ systems. Businesses may have legitimate reasons to do this. For example, when a consumer moves to a new home, a business may reasonably seek to update data previously corrected by a consumer by changing the previous address to the new, publicly available address for the consumer. The current wording of the proposed regulations could create unintended results, such as requiring businesses to keep outdated information in their systems despite learning new information to the contrary. Such a rigid requirement would cause significant consumer frustration when, for example, address changes and other new data elements are not able to be updated seamlessly in businesses’ systems. To ameliorate potential unintended results, the Agency should apply requirements to ensure information “remains” corrected or deleted only to previously collected personal information.

d. Proposed New Requirements Related to Data Sources Should Remain Optional

In the context of correction requests, the currently effective CCPA regulations give businesses the option of providing the consumer with the name of the source of alleged inaccurate information if the business itself is not the source of the information.⁴³ The proposed updates to the regulations would make this option mandatory, or would require businesses to inform the source that the information provided is incorrect and must be corrected.⁴⁴ The Agency should retain the

⁴² Cal. Code Regs. tit. 11, §§ 7022(b), (c), (f); 7023(c); 7023(k) (proposed).

⁴³ *Id.* at § 7023(i).

⁴⁴ *Id.* (proposed).

present regulatory text, which makes disclosing the names of data sources optional. Businesses should not be required to disclose the names of their partners and customers. Maintaining the optional nature of the present rule would help avoid anti-competitive effects, ensure businesses can continue to meet confidentiality requirements they may be subject to through contracts with their data sources, and to protect trade secrets.

e. The Regulations Should Clarify How Businesses Can Confirm Certain Sensitive Personal Information

In the context of access and correction requests for specific sensitive pieces of personal information, such as government-issued identification numbers, financial account numbers, health insurance or medical identification numbers, account passwords, security questions and answers, and unique biometric data, the proposed regulations would require businesses to provide consumers with “a way” to confirm that the personal information maintained is the same as what the consumer provided or what the consumer “believes it should be.”⁴⁵ The Agency should clarify acceptable “ways” businesses can meet this new requirement while minimizing the possibility of exposing sensitive data elements to fraudsters or others who are not the consumer to which the personal information pertains. To protect sensitive personal information from unnecessary exposure and to provide meaningful clarity, the CCPA should state that businesses may satisfy this requirement by confirming the type of data elements they maintain or by confirming redacted or truncated portions of the information to reduce the potential for unnecessary data leakage.

f. The Scope of CCPA Applicability for Nonprofits Should Be Clarified and Aligned with the Statute

The proposed regulation would update the definition of “nonbusiness,” subsequently creating confusion regarding the scope of the CCPA’s applicability to nonprofits.⁴⁶ The CCPA defines “business” to include any for-profit entity that processes personal information related to California consumers, or on behalf of which such information is processed, and controls the purpose and means of the processing.⁴⁷ As drafted, the definition reflects legislative intent to cabin applicability of the CCPA to for-profit entities. In addition, the California Attorney General has noted in FAQs that “[t]he CCPA generally does not apply to nonprofit organizations[.]”⁴⁸ The Agency should take steps to align the proposed regulations with the text of the statute by including text that appropriately limits the CCPA’s applicability to nonprofits.

g. Notice Requirements Should Be Channel Agnostic and Should Allow for Flexibility in Connected Device Settings

The proposed regulations would require businesses to “ensure the consumer will encounter” applicable notices before connected devices or augmented reality/virtual reality devices may collect

⁴⁵ *Id.* at §§ 7023(j); 7024(d) (proposed).

⁴⁶ *Id.* at § 7001(x) (proposed).

⁴⁷ Cal. Civ. Code 1798.140(d).

⁴⁸ Rob Bonta, Attorney General, *California Consumer Privacy Act Frequently Asked Questions (FAQs)*, located [here](#).

personal information.⁴⁹ The proposed regulations would also require notice of the right to limit to be provided in the same “manner” in which the business collects sensitive personal information.⁵⁰ These prescriptive requirements do not provide enough flexibility for business to reach consumers with notices on different channels and through more accessible and consumer-friendly methods. They also do not consider changes in technology, which may not permit notices to be served through the medium that actually collects personal information to provide a service.

Appropriate flexibility should be afforded to permit notices to be provided in ways that consumers will best receive and understand them. For example, smart speakers or other devices without screens may be best suited to provide requisite notices through applications that accompany the device rather than through the speaker itself, as a written form of the notice may be easier for a consumer to review for pertinent information. Moreover, overly prescriptive requirements regarding methods of notice are likely to lead to increased administrative burdens, higher costs, and potential compliance issues, especially for small businesses. These costs will ultimately fall to consumers in terms of frustrated access to innovative offerings, new AR/VR tools, and new connected devices. Flexibility in the form of notice should be permitted to ensure that businesses can provide disclosures in ways that are helpful and logical for consumers.

III. The CCPA Should Permit Businesses at Least a Year to Comply with New Mandates Before They Become Enforceable

Given the breadth and scope of the proposed updates to existing CCPA regulations, cybersecurity audit requirements, and new ADMT rules, the CCPA should clarify that civil and administrative enforcement of new regulatory provisions will not commence until one year from the date the provisions are in effect. The CCPA should make clear that the requirements in new regulations apply to processing activities created or generated after December 31, 2026 only and are not retroactive to any processing activities created or generated before January 1, 2027. Providing a ramp-up period for businesses’ compliance with complex and confusing new requirements and audit standards would help afford much-needed time to assess the universe of ADMT applications subject to the rules, build new cybersecurity audit processes, formulate rational approaches to compliance, and stand-up processes associated with entirely new opt-out and risk assessment mandates.

* * *

⁴⁹ Cal. Code Regs. tit. 11, § 7013(e)(3) (proposed).

⁵⁰ *Id.* at § 7014(e)(3) (proposed).



Thank you in advance for your consideration of these comments.

Sincerely,

Christopher Oswald
EVP for Law, Ethics & Govt. Relations
Association of National Advertisers
202-296-1883

Alison Pepper
EVP, Government Relations & Sustainability
American Association of Advertising Agencies, 4As
202-355-4564

Lartase Tiffith
Executive Vice President, Public Policy
Interactive Advertising Bureau
212-380-4700

Clark Rector
Executive VP-Government Affairs
American Advertising Federation
202-898-0089

Lou Mastria, CIPP, CISSP
Executive Director
Digital Advertising Alliance
347-770-0322

CC: Mike Signorelli, Venable LLP
Allie Monticollo, Venable LLP